



DataShield Enterprise

Data Loss Prevention Platform

Complete Administrator & User Guide

Architecture reference, role definitions, setup instructions, admin workflows, employee onboarding, DLP engine internals, security model, and quick-reference guide.

FastAPI Backend

React Dashboard

Tkinter Admin Console

AES-256-GCM Encryption

AI-Powered

01

Introduction

What DataShield is, why it exists, and how it fits into enterprise DLP.

What is DataShield?

DataShield Enterprise is a Data Loss Prevention (DLP) platform built to protect organisations from the accidental or malicious leakage of sensitive information by employees. It operates as a silent endpoint agent that continuously monitors how employees interact with sensitive data -- scanning documents, watching clipboard usage, monitoring USB drives, and intercepting outgoing emails -- and reports every policy violation to a central server for review by security operations and IT administrators.

DLP is the practice of detecting and preventing data breaches, exfiltration, and unwanted destruction of sensitive data. DataShield implements DLP at the endpoint level -- meaning it runs directly on the employee's workstation, giving it access to local files, clipboard contents, USB insertions, and outgoing webmail that no browser-based or network-only tool could see.

Why DLP Matters

Every organisation handles sensitive data: employee records, client contracts, financial statements, healthcare records, intellectual property, API keys, and personally identifiable information (PII). The cost of a data breach in 2024 averaged USD 4.88 million (IBM Cost of a Data Breach Report 2024). Most breaches are caused by insiders -- not external hackers.

DataShield addresses three categories of insider risk:

- * Accidental: An employee emails a spreadsheet with SSNs to the wrong recipient.
- * Negligent: An employee copies client data to a personal USB drive for convenience.
- * Malicious: A departing employee exfiltrates intellectual property before resignation.

How DataShield Compares to Enterprise DLP Solutions

Feature	DataShield	Microsoft Purview	Forcepoint DLP
Endpoint agent	Yes	Yes	Yes
Clipboard monitoring	Yes	Limited	Yes
USB drive monitoring	Yes	Yes	Yes
Email interception	Yes (webmail)	Yes (all clients)	Yes
File scanning	Yes	Yes	Yes
AI-powered explanation	Yes (Gemini)	Yes (Copilot)	Partial
Envelope encryption	Yes (AES-256-GCM)	Yes	Yes
On-premise deployment	Yes	Hybrid	Yes
Open source/auditable	Yes	No	No

02

Architecture

System components, data flows, database design, and the security model.

System Architecture Overview

DataShield is a multi-tier system with four distinct components. Each component has a clearly defined responsibility and communicates with the others only through well-defined HTTP APIs or WebSocket connections. No component can bypass the server's authorization checks.

The Four Components

Component	Technology	Who Uses It	Purpose
FastAPI Server	Python / FastAPI	All components	Central API, database, business logic
Employee Agent	Python / Tkinter	Employees	Endpoint monitoring, local file scanning
Admin Console	Python / Tkinter	IT helpdesk	Enroll employees, set PINs, configure channels
Web Dashboard	React / TypeScript	Security ops	Monitor events, alerts, policies, compliance

Data Flow -- From Detection to Dashboard

1

The employee agent's background monitors detect a policy violation -- e.g., sensitive text in the clipboard, a file with PII being written to a USB drive, or an outgoing webmail message containing a credit card number.

2

The scanner engine runs pattern matching against all active DLP policies. Each match is weighted by its `base_weight`. The classifier aggregates matches into a `risk_score` (0-100) and assigns a `risk_level`: CLEAN, LOW, MEDIUM, or HIGH.

3

If `GEMINI_API_KEY` is configured and the risk level is HIGH or MEDIUM, Gemini generates a human-readable explanation of why the content was flagged. This is encrypted and stored alongside the event.

4

The agent sends the event to `POST /api/agents/events`. The file path and AI explanation are encrypted using the employee's Data Encryption Key (DEK) via AES-256-GCM before storage. The server never stores plaintext file paths or explanations.

5

On every ingested event, the server recalculates the employee's `risk_score` using a weighted formula accounting for violation severity, time-of-day anomalies, volume spikes, and repeat pattern violations within 24 hours.

6

The alert engine evaluates whether the event meets severity thresholds. If it does, an alert is created or an existing open alert is escalated. Alerts are deduplicated within 4-hour windows to prevent alert fatigue.

7

Database Schema

Table	Key Columns	Purpose
admin_users	id, email, hashed_password, role, is_active	Admin logins
employees	id, email, risk_score, risk_level, is_flagged, encrypted_dek	Enrolled employees
agents	id, hostname, employee_id, employee_name, is_active, last_he	Endpoint agents
dlp_events	id, employee_id, channel, risk_level, file_path_encrypted	All DLP violations
policies	id, name, category, pattern, base_weight, regulation_tags	DLP detection rules
alerts	id, employee_id, severity, status, escalation_count, top_pat	Security alerts

Security Architecture -- Envelope Encryption

Why envelope encryption?

If a single employee's DEK is compromised, only that employee's data is at risk.

The master key and other DEKs remain safe. This is the same model AWS uses for S3 server-side encryption and Azure Blob Storage encryption.

03

Roles & Access Control

Who can do what, and why access is restricted the way it is.

Role Definitions

DataShield has two separate authentication systems. Admin users (superadmin, analyst, viewer) log into the web dashboard and admin console using email + password. Employees log into the endpoint agent using email + PIN. These systems are completely independent with separate database tables and separate authentication endpoints.

Admin-Side Roles

SUPERADMIN

Who: IT Security Manager, CISO, Head of IT

Can:

- + Full access to all features on web dashboard and admin console
- + Create, edit, and delete admin user accounts
- + Enroll employees and set their login PINs
- + Manage DLP policies (create, edit, delete, push to all agents)
- + Trigger encryption key rotation for all employees
- + View all events including decrypted file paths
- + Flag and unflag employees for review
- + Generate compliance reports and Gemini AI executive summaries
- + Configure per-employee monitoring channel settings

Cannot:

- Nothing is restricted for this role

ANALYST

Who: Security Operations Centre (SOC) analyst, DLP reviewer

Can:

- + View all events, alerts, employees, and agents on the web dashboard
- + Acknowledge and resolve alerts
- + Flag and unflag employees for review
- + View decrypted file paths in the Events page
- + Generate compliance reports and Gemini AI summaries
- + View DLP policy rules (read-only)

Cannot:

- Cannot create or modify DLP policies
- Cannot trigger encryption key rotation
- Cannot create or manage admin user accounts
- Cannot access the Admin IT Console
- Cannot enroll employees or set employee PINs

VIEWER

Who: Compliance officer, external auditor, department manager

Can:

- + View event list (file paths remain encrypted/hidden)
- + View alerts (read-only, cannot acknowledge or resolve)
- + View employee risk levels and scores
- + View compliance metrics on the dashboard

- Cannot view decrypted file paths or AI explanations
- Cannot acknowledge, resolve, or escalate alerts
- Cannot flag or unflag employees
- Cannot access Policies or Encryption pages
- Cannot generate reports or AI summaries
- Cannot access the Admin IT Console

Employee Authentication

Employees are not admin users. They authenticate via the endpoint agent using their work email and a PIN set by the IT admin. Employees have no access to the web dashboard or admin console.

- * Employee PINs are bcrypt-hashed server-side. The admin never sees the plain PIN.
- * If no PIN has been set, the agent shows 'No PIN set yet' and the employee must contact their IT admin before they can proceed.
- * The agent authenticates with the server using the AGENT_API_KEY header (a shared secret configured in .env). This prevents unauthenticated agents from reporting events.

Access Control Matrix

Action	Superadmin	Analyst	Viewer	Employee
View live events dashboard	Yes	Yes	Yes	No
View decrypted file paths	Yes	Yes	No	No
Acknowledge and resolve alerts	Yes	Yes	No	No
Flag and unflag employees	Yes	Yes	No	No
Create and edit DLP policies	Yes	No	No	No
Push policies to agents	Yes	No	No	No
Trigger encryption key rotation	Yes	No	No	No
Manage admin user accounts	Yes	No	No	No
Access Admin IT Console	Yes	No	No	No
Enroll employees and set PINs	Yes	No	No	No
Generate compliance reports	Yes	Yes	No	No
Generate Gemini AI summary	Yes	Yes	No	No
Log in to endpoint agent	No	No	No	Yes
Scan files locally	No	No	No	Yes
View own scan results	No	No	No	Yes

04

Installation & Setup

Prerequisites, .env configuration, database setup, and first server start.

Prerequisites

System Requirements

Component	Requirement
Python	3.10 or higher (3.12 recommended)
PostgreSQL	14 or higher
Node.js	18 or higher (for web dashboard only)
Operating System	Windows 10/11, Ubuntu 20.04+, macOS 12+
RAM	Min 512 MB for server; 256 MB for endpoint agent
Network	Employees must reach the server on the configured port (defa
Gemini API Key	Optional -- enables AI explanations and executive summaries
SMTP server	Optional -- enables email alert notifications

Project Directory Layout

Project layout

datashield/	
server/	FastAPI backend
api/	HTTP route handlers (auth, agents, employees, alerts...)
models/	SQLAlchemy ORM models (employee, agent, event, alert...)
services/	Business logic (alert engine, behaviour, crypto service)
alembic/	Database migration scripts
config.py	Settings loaded from .env via pydantic-settings
main.py	FastAPI app with lifespan, CORS, routers, scheduler
gui/	Tkinter UI components
main_window.py	Employee agent window (Scan Files + Detections)
admin_window.py	Admin IT Console (Enrollment + Employees + Agents)
scan_tab.py	File scanning tab widget
results_tab.py	Scan results display tab
monitoring_dialog.py	Per-employee channel toggle dialog
comms/	Background monitoring modules
clipboard_monitor.py	Real-time clipboard DLP monitor
usb_watcher.py	USB drive insertion detection and scanning
http_server.py	Local HTTP server for webmail/browser extension scanning
crypto/	
encryption.py	AES-256-GCM encrypt/decrypt + PBKDF2 key derivation
dashboard/	React TypeScript web dashboard (Vite)
src/pages/	Login, Dashboard, Employees, Events, Alerts...
src/components/	RiskBadge, LiveFeed, ViolationChart, Navbar...
src/api/	Axios API client with JWT auto-attachment
main.py	Employee agent entry point (login + tray + monitors)

[quick_scan.py](#)

Quick scan shortcut (login + folder picker)

[rules/](#)

Default DLP policy YAML files (loaded on first run)

Configuration -- The .env File

All secrets and configuration values are loaded from a .env file in the project root. NEVER commit this file to version control. Start by copying the example:

Create .env

```
copy .env.example .env    # Windows
cp .env.example .env      # Linux / macOS
```

Edit .env and fill in every value:

.env file -- full example

```
# -- Database -----
DATABASE_URL=postgresql+asyncpg://user:password@localhost:5432/datashield

# -- Security (CHANGE ALL OF THESE -- server will not start otherwise) --
JWT_SECRET_KEY=your-256-bit-random-string-here
MASTER_KEY_PASSPHRASE=your-strong-encryption-passphrase
AGENT_API_KEY=your-secret-agent-to-server-shared-key

# -- Server URL (what the agent uses to reach the server) -----
SERVER_URL=http://localhost:8001

# -- Gemini AI (optional, remove if not using) -----
GEMINI_API_KEY=your-gemini-api-key-from-aistudio.google.com

# -- SMTP Email Alerts (optional, remove if not using) -----
SMTP_HOST=smtp.gmail.com
SMTP_PORT=587
SMTP_USER=alerts@yourcompany.com
SMTP_PASSWORD=your-app-specific-password
SMTP_FROM=DataShield Alerts <alerts@yourcompany.com>
ALERT_EMAIL_RECIPIENTS=security@yourcompany.com,ciso@yourcompany.com
```

CRITICAL -- Startup Secret Guard

The server will REFUSE to start if JWT_SECRET_KEY, MASTER_KEY_PASSPHRASE, or AGENT_API_KEY still contain the word 'CHANGEME'. This is intentional -- deploying with default secrets would be a critical security vulnerability.

Generate cryptographically secure random secrets using Python:

Generating secrets

```
python -c "import secrets; print(secrets.token_hex(32))" # for JWT_SECRET_KEY
python -c "import secrets; print(secrets.token_hex(24))" # for AGENT_API_KEY
```

Database Setup

1

Log into PostgreSQL and run:

```
CREATE DATABASE datashield;  
CREATE USER ds_user WITH PASSWORD 'strong-password';  
GRANT ALL PRIVILEGES ON DATABASE datashield TO ds_user;
```

2

From the datashield/ directory:

```
python -m venv venv  
venv\Scripts\activate      (Windows)  
source venv/bin/activate   (Linux/macOS)  
pip install -r server/requirements.txt
```

3

Apply the initial schema to create all tables:

```
python -m server.migrate
```

This creates: admin_users, employees, agents, dlp_events, policies, alerts.

4

Create the account you will use to log into the web dashboard and admin console:

```
python -m server.init_db
```

Follow the prompts to set the superadmin email, full name, and password.

5

Start the server and confirm there are no errors:

```
uvicorn server.main:app --host 0.0.0.0 --port 8001 --reload
```

Open <http://localhost:8001/docs> to see the interactive API documentation.

If the server refuses to start, check that all CHANGEME values are replaced in .env.

05

Running the Application

How to start every component and what each one does on startup.

Starting Each Component

1. FastAPI Server -- Start This First

The server is the backbone. Every other component communicates with it. Always start the server before the dashboard, admin console, or employee agents.

Start the FastAPI server

```
# Development (with auto-reload on code changes):
uvicorn server.main:app --host 0.0.0.0 --port 8001 --reload

# Production (multiple workers, no reload):
uvicorn server.main:app --host 0.0.0.0 --port 8001 --workers 4
```

What happens on startup:

- * Secret validation -- refuses to start with CHANGEME defaults in .env
- * Database table creation (development mode) or schema verification
- * Default DLP policies seeded from rules/default_rules.yaml if the policies table is empty
- * APScheduler starts -- anomaly detection job runs every 15 minutes
- * WebSocket connection manager initialised for real-time dashboard broadcasting

2. Web Dashboard -- Security Operations

The React dashboard requires Node.js. Install npm dependencies on first run only:

Start the web dashboard

```
cd dashboard
npm install      # first time only
npm run dev      # starts on http://localhost:5173
```

Log in with the superadmin (or analyst/viewer) email and password created during init_db. The dashboard connects to the server at the URL configured in dashboard/.env (VITE_API_URL).

3. Admin IT Console -- IT Helpdesk

The Admin IT Console is a Tkinter desktop application for IT admins. Run it on the IT admin's machine which must have network access to the server.

Start the Admin IT Console

```
# Either method works:
python admin_console.py
python -m server.run_admin_console
```

A login dialog appears. Enter your admin email and password (not a PIN -- the admin console uses password

4. Employee Endpoint Agent

The endpoint agent runs on each employee's workstation. The employee must have been enrolled by an IT admin (and given a PIN) before they can log in.

Start the employee agent

```
# Full agent with system tray and all monitors:
python main.py

# Quick scan shortcut (login -> folder picker -> scan window):
python quick_scan.py
```

The agent will:

- * Show a login dialog (email + PIN)
- * Verify credentials with `/api/auth/validate-employee` on the server
- * Register the machine as an agent via `/api/agents/register`
- * Start background monitors based on admin-configured channel settings
- * Minimise to the system tray -- the employee sees only a shield icon
- * Send all detected violations to the server automatically via HTTPS

Quick Reference -- All Commands

Complete command reference

```
# Server
uvicorn server.main:app --host 0.0.0.0 --port 8001 --reload

# Database
python -m server.migrate      # Apply migrations (run after install)
python -m server.init_db      # Create superadmin account (run once)

# Web Dashboard
cd dashboard && npm run dev    # http://localhost:5173

# Admin IT Console
python admin_console.py

# Employee Agent
python main.py

# Employee Quick Scan Shortcut
python quick_scan.py
```

06

Admin Console Guide

IT helpdesk workflows: enrolling employees, setting PINs, managing monitoring.

Admin Console Overview

The Admin IT Console (admin_console.py) is the primary tool for IT helpdesk staff. Its purpose is narrow and specific: onboard new employees, set their PINs, configure which monitoring channels are active for each person, and verify endpoint agent connectivity. It is not designed for monitoring events or reviewing compliance -- those tasks belong to the web dashboard.

The Admin Console and the Web Dashboard are complementary, not competing tools.

Admin Console --> IT helpdesk: enroll, configure, support

Web Dashboard --> Security ops: monitor, alert, comply, report

Overview Tab

The Overview tab shows a quick health summary of the DataShield deployment. It displays total enrolled employees, flagged employee count, open alert count, today's event count, and a table of recent agent connections. Click Refresh to update. For live real-time updates, use the web dashboard.

Employees Tab

The Employees tab lists all enrolled employees. Each row shows name, email, department, risk level, risk score, and flag status.

Setting a PIN

Every employee needs a PIN before they can log into the endpoint agent.

1

Load the current employee list.

2

Click the PIN button next to the employee's row.

3

Type a PIN of at least 4 characters and click OK.

4

Tell the employee their PIN via a secure channel (not email).

Configuring Monitoring Channels

Each employee can have individual channels enabled or disabled.

1

Click the Monitoring button next to the employee.

Toggle channels

Enable or disable:

- Clipboard Monitoring -- intercepts copy/paste of sensitive text
- USB Drive Monitoring -- alerts when files are written to USB drives
- Webmail / Email -- scans outgoing webmail message content
- File Scanning -- allows employee to use the manual scan feature

3

Click Save. The agent picks up the new settings on its next heartbeat (within 5 minutes).

Flagging and Unflagging an Employee

Flagging marks an employee as under active review. It does not change what is monitored -- it is a status indicator visible to the security team.

- * To flag: click [Flag] next to the employee, enter a reason, confirm.
- * To unflag: click [Unflag] next to the employee, confirm.

Enroll New Employee Wizard

The 4-step Enrollment Wizard is the correct onboarding workflow for new employees. It ensures no step is missed.

1

Enter full name, work email, department, and job title.

Click 'Create Employee & Continue'.

The employee record is created and a unique encryption key (DEK) is generated.

2

Enter a PIN (minimum 4 characters) and confirm it.

Click 'Set PIN & Continue'.

The PIN is bcrypt-hashed server-side. You cannot retrieve it later.

3

Select which DLP channels are active for this employee.

All channels are enabled by default.

Click 'Apply & Finish'.

4

The wizard displays setup instructions to give to the employee:

1. On their workstation, run: `python main.py`
2. Enter email and PIN
3. DataShield activates and minimises to system tray
4. Right-click tray icon to open agent or scan files

Agent Status Tab

Shows all registered endpoint agents. An agent registers automatically when an employee runs `main.py` for the first time on a new machine.

Column

Meaning

Status	ONLINE (green) if last heartbeat < 5 min ago; OFFLINE (red)
Employee	The employee this agent belongs to
Hostname	The machine name (e.g., JOHNS-LAPTOP, ENGINEERING-PC-04)
Platform	Operating system (win32, linux, darwin)
Last Seen	Time since the last heartbeat (e.g., 2m ago, 3h 15m ago)

07

Web Dashboard Guide

The security operations centre: monitoring, alerts, policies, encryption, reports.

Web Dashboard Overview

The React web dashboard at `http://localhost:5173` is the primary interface for security operations. It provides real-time monitoring via WebSocket, compliance metrics, policy management, encryption key management, and Gemini AI-powered executive summaries.

Dashboard Page (Home)

Four metric cards updated in real time:

- * Total Events Today -- all DLP events detected since midnight
- * HIGH Violations -- HIGH risk events today
- * Active Alerts -- open unacknowledged alerts
- * Flagged Employees -- employees currently under review

Below the metric cards:

- * Live Event Feed -- real-time stream of events via WebSocket as they are detected
- * Violation Chart -- bar chart of events over the last 7 days by risk level
- * Risk Heatmap -- treemap of employees sized by current risk score

Events Page

A paginated, searchable log of every DLP event. Newest events appear first.

Column	Meaning	Visible To
Channel	Where detected (CLIPBOARD, USB, WEBMAIL, FILE)	Everyone
Employee	Which employee triggered the violation	Everyone
Risk Level	CLEAN / LOW / MEDIUM / HIGH (colour coded)	Everyone
Action Taken	BLOCK / WARN / LOG -- what the agent did	Everyone
Pattern	Which policy pattern matched (e.g. CREDIT_CARD)	Everyone
File Path	Local file path, decrypted on demand	Superadmin, Analyst
AI Explanation	Gemini explanation of why content was flagged	Superadmin, Analyst
Timestamp	When the violation occurred (employee local time)	Everyone

Alerts Page

The alert inbox for security operations.

Alert Severity Levels

Severity	Trigger Condition	Notification
CRITICAL	HIGH event on EMAIL/WEBMAIL channel OR risk_score > 20.0	Email + WebSocket
HIGH	HIGH event on non-email channel OR 3+ MEDIUM violations in 7	Email if configured + WebSocket
MEDIUM	Volume spike >3x baseline OR first USB event ever	WebSocket only

Alert Actions

- * Acknowledge: marks alert as ACKNOWLEDGED, removes from active queue
- * Resolve: marks alert as RESOLVED, logs resolution timestamp

Alert deduplication: if the same employee triggers the same pattern within 4 hours of an existing open alert, the alert's `escalation_count` is incremented rather than creating a duplicate. This prevents alert fatigue.

Policies Page

DLP policies define what patterns the scanner detects and how much weight each match carries.

Field	Description	Example
name	Unique policy identifier	CREDIT_CARD_PAN
category	PII / FINANCIAL / HEALTH / LEGAL / CUSTOM	FINANCIAL
pattern	Python regex to match against content	4[0-9]{12}(?:[0-9]{3})?
base_weight	Risk multiplier (0.1 to 10.0)	4.5
regulation_tags	Regulations this policy covers	PCI-DSS, GDPR
description	Human-readable explanation	Visa card (16 digits)

Only SUPERADMIN can create, edit, or delete policies.

Click 'Push to all agents' to distribute policy changes to every active endpoint.

Agents receive updates on their next heartbeat (within 5 minutes).

Encryption Page

Shows the state of the envelope encryption system:

- * Master Key Age -- how long since the MASTER_KEY_PASSPHRASE was last changed
- * Total DEKs -- number of per-employee encryption keys in the system
- * Rotation Status -- green (OK) or amber (rotation recommended based on key age)

Key Rotation

Clicking 'Rotate All Keys' triggers:

1. A new 256-bit DEK is generated for each employee
2. All existing encrypted events are decrypted with the old DEK
3. They are re-encrypted with the new DEK
4. The new DEK (encrypted with master key) replaces the old one in the database

This is safe to run at any time and does not interrupt ongoing monitoring.

Reports Page

Compliance Metrics Report

A JSON-formatted compliance audit covering: total events by risk level and channel, blocked vs. warned events, regulation hit counts (GDPR, PCI-DSS, HIPAA, etc.), flagged employee count, and open alert count.

Requires GEMINI_API_KEY. Feeds live compliance numbers to Gemini and receives a 3-5 sentence executive summary of the current security posture, plus the top 3 recommended remediation actions. Suitable for CISO briefings.

08

Employee Guide

What the endpoint agent does, how to use it, and what to expect when it flags content.

The Employee Endpoint Agent

When you run 'python main.py' on your workstation, DataShield activates and begins protecting your organisation's data. Here is exactly what happens and what you can do.

First Login

1

Open a terminal in the DataShield folder and run: python main.py

2

Type your work email address -- the same one your IT admin registered you with.

3

Type the PIN your IT admin gave you. It displays as dots for privacy.

4

DataShield verifies your credentials, registers this machine, starts background monitors, and minimises to the system tray. You will see a shield icon in the taskbar notification area.

- If you see 'No PIN set yet' -- contact your IT admin to set your PIN.
- If you see 'Email not registered' -- your IT admin needs to enroll you first.
- If you see 'Cannot reach server' -- check you are on the company network or VPN.

Background Monitors

Monitor	What it watches	What it does when triggered
Clipboard	Every Ctrl+C (copy) action	Scans copied text against DLP policy patterns
USB	USB drive insertions	Scans files written to the USB for sensitive data
Webmail	Outgoing emails composed in browser	Browser extension sends email content for scanning
File Scanner	Manual scans you initiate	Scans a folder you select before sending documents

Your IT admin may have disabled some monitors for your account based on your role or employment contract. The agent will show which channels are active on startup.

Scanning Files Before Sending

Before emailing a folder of documents, you can scan it yourself to check for sensitive content -- the same check your IT security policy requires.

1

Right-click the DataShield shield icon in the taskbar.

Choose this option from the menu.

3

Browse to the folder and click OK.

4

DataShield shows each file with a colour-coded risk level:

GREEN (CLEAN) -- safe to send

YELLOW (LOW/MEDIUM) -- review recommended

RED (HIGH) -- contains sensitive data, do not send without authorisation

5

Remove or redact sensitive files before sending. If you believe the flagging is a false positive, note the file name and contact your manager or IT admin.

What Happens When a Violation Is Detected

- * The event is logged locally to datashield_agent_audit.log
- * The event is sent to the DataShield server (encrypted, no plaintext in transit)
- * A desktop notification describes what was detected
- * HIGH risk on email: the send may be BLOCKED (email does not go out)
- * MEDIUM risk: a WARNING notification is shown, action is allowed
- * LOW risk: logged silently with no notification

If you receive a DataShield email notification, a HIGH or CRITICAL level violation was detected on your account. If you performed this action with proper authorisation, no action is needed. If you did NOT perform this action, contact your IT admin immediately -- your account may have been compromised.

09

DLP Engine Internals

How scanning, risk scoring, alert evaluation, and anomaly detection work under the hood.

The DLP Detection Pipeline

Pattern Matching

Every DLP policy contains a Python regular expression. When content is scanned, all active policy patterns are applied. Each match records:

- * Which policy pattern matched (e.g. CREDIT_CARD_PAN, SSN, IBAN)
- * The matched value (stored redacted -- only the last 4 characters shown)
- * The base_weight of the matched policy (used in risk score calculation)
- * The regulation_tags covered (GDPR, PCI-DSS, HIPAA, SOC2, etc.)

Risk Score Calculation

The employee's risk_score is recalculated on every ingested event. The formula applies multipliers for anomalous conditions:

Risk score formula (server/services/behaviour.py)

```
# Base score from violation counts in the last 7 days
base_score = (high_count * 4.0) + (medium_count * 1.5) + (low_count * 0.3)

# Volume multiplier -- penalise sudden spikes above 2x the 30-day average
volume_multiplier = 1.5 if total_events_7d > 2 * daily_avg_30d * 7 else 1.0

# Time multiplier -- penalise after-hours activity (10pm to 6am local time)
time_multiplier = 1.3 if any_event_outside_business_hours else 1.0

# Repeat multiplier -- penalise same pattern triggered >3 times in 24h
repeat_multiplier = 1.4 if same_pattern_triggered_gt3_in_24h else 1.0

final_score = base_score * volume_multiplier * time_multiplier * repeat_multiplier

# Risk level thresholds
if final_score >= 10.0: risk_level = 'HIGH'      # Employee is auto-flagged
elif final_score >= 4.0: risk_level = 'MEDIUM'
elif final_score >= 1.0: risk_level = 'LOW'
else:
    risk_level = 'CLEAN'
```

Anomaly Detection

The anomaly detector runs automatically every 15 minutes across all employees:

Anomaly Type	Condition	Alert Created
Volume Spike	Last 24h events > 3x the 30-day daily average for an employee	MEDIUM alert

Alert Engine Logic

1

HIGH event on EMAIL or WEBMAIL channel -> CRITICAL
HIGH event on other channel (CLIPBOARD, USB, FILE) -> HIGH
MEDIUM event AND employee.high_violations_7d >= 3 -> HIGH

2

If employee.risk_score > 20.0 AND employee is not already flagged:
-> Auto-flag the employee (is_flagged = True)
-> Create CRITICAL alert: 'Employee risk threshold exceeded'

3

Check for an existing open alert for this employee + pattern in the last 4 hours.
If found: increment escalation_count (no new alert created).
If not found: create a new alert record.

4

Broadcast the alert payload to all connected web dashboard clients in real time.

5

CRITICAL: send email immediately to all admin recipients AND the employee.
HIGH: send email if SMTP is configured.
SMTP is skipped if SMTP_HOST is 'localhost' (development mode -- no email sent).

10

Troubleshooting & Quick Reference

Common errors, how to fix them, and a complete API endpoint reference.

Troubleshooting

Server Startup Errors

Error	Cause	Fix
RuntimeError: CHANGEME defaults	Secrets not set in .env	Edit .env with real secret values
asyncpg.InvalidCatalogNameError	Database does not exist	CREATE DATABASE datashield; in psql
ModuleNotFoundError: server.X	venv not activated	Run venv activation command first
Address already in use :8001	Port 8001 is taken by another process	Kill other process or change port
401 on /api/auth/login	Wrong email or password	Re-run python -m server.init_db

Employee Agent Errors

Error / Symptom	Cause	Fix
Cannot reach server	Server not running / wrong SERVER_URL	Start server; check .env SERVER_URL
Email not registered	Employee not enrolled	Admin must enroll in Admin Console
No PIN set yet	Admin has not set a PIN for this account	Admin must set PIN in Employees tab
Wrong PIN	Incorrect PIN entered	Contact IT admin to reset PIN
GUI does not open	Tkinter not installed	Install Python with Tk support
Clipboard monitor fails	pyperclip not installed in venv	pip install pyperclip

Web Dashboard Issues

Issue	Fix
Blank page or CORS error	Check CORS_ORIGINS in server config includes http://localhost
Login fails with 401	Verify superadmin exists; re-run python -m server.init_db
Events page empty	No events yet; run an employee agent and trigger a scan
WebSocket not connecting	Check VITE_WS_URL in dashboard/.env matches server URL
npm run dev fails	Run: cd dashboard && npm install first

API Endpoint Reference

Authentication Endpoints

Method	Path	Auth Required	Returns
POST	/api/auth/login	None	JWT tokens + role + full_name + email
POST	/api/auth/refresh	None	New access token and refresh token
GET	/api/auth/me	JWT	Current admin user profile
POST	/api/auth/validate-employee	AgentKey	Employee role + name + monitoring settings

Agent Endpoints

Method	Path	Auth	Description
GET	/api/agents	JWT	List all registered agents with is_online status
POST	/api/agents/register	AgentKey	Register a new endpoint agent, returns agent_id
POST	/api/agents/heartbeat	AgentKey	Heartbeat ping; returns policy_update_available
GET	/api/agents/{id}/policy	AgentKey	Fetch current active DLP policies for this agent
POST	/api/agents/events	AgentKey	Ingest a batch of DLP events (encrypted)

Employee Endpoints

Method	Path	Auth	Description
GET	/api/employees	JWT	Paginated employee list (search, page)
POST	/api/employees	JWT Admin	Create a new employee record
GET	/api/employees/{id}	JWT	Get single employee detail
POST	/api/employees/{id}/flag	JWT	Flag employee for review with reason
POST	/api/employees/{id}/unflag	JWT	Remove flag from employee
POST	/api/employees/{id}/set-pin	JWT Admin	Set or reset employee login PIN
PATCH	/api/employees/{id}/monitoring	JWT Admin	Update per-channel monitoring settings

Alerts, Events, Reports, Policies, Encryption

Method	Path	Auth	Description
GET	/api/events	JWT	Paginated event log with channel/risk filters
GET	/api/events/{id}	JWT	Event detail; decrypts paths for analyst+
GET	/api/alerts	JWT	List open alerts with severity and employee
POST	/api/alerts/{id}/acknowledge	JWT	Mark alert as ACKNOWLEDGED
POST	/api/alerts/{id}/resolve	JWT	Mark alert as RESOLVED

GET	/api/reports/overview	JWT	Fast summary counts for admin console
GET	/api/reports/metrics	JWT	Full compliance metrics JSON
GET	/api/reports/executive-summary	JWT	Gemini AI executive summary (analyst+)
GET	/api/policies	JWT	List all DLP policies
POST	/api/policies	JWT Admin	Create a new DLP policy
DELETE	/api/policies/{id}	JWT Admin	Delete a DLP policy
POST	/api/policies/push	JWT Admin	Mark all agents for policy update
GET	/api/encryption/status	JWT Admin	Key age and DEK count
POST	/api/encryption/rotate	JWT Admin	Rotate all employee DEKs

WebSocket

WebSocket endpoint: `ws://localhost:8001/ws/events?token=<your-JWT>`

Message types broadcast to connected clients:

EVENT: { type, channel, risk_level, employee_id, employee_email }

ALERT: { type, id, severity, title, employee_id, employee_email }

The web dashboard connects automatically on login. On disconnect, it reconnects with exponential backoff (1s, 2s, 4s, 8s... up to 60s between attempts).

Glossary

Term	Definition
DLP	Data Loss Prevention -- detecting and preventing data exfiltration
Endpoint Agent	Software running on an employee's workstation, not on the server
DEK	Data Encryption Key -- a unique AES-256 key per employee
Envelope Encryption	Encrypting a DEK with a master key; industry standard key hierarchy
AES-256-GCM	The cipher used -- 256-bit key, authenticated (tamper-evident)
PBKDF2	Password-Based Key Derivation Function 2 -- derives master key from password
JWT	JSON Web Token -- the stateless auth token used for admin API
APScheduler	Python library running anomaly detection every 15 minutes
WebSocket	Persistent bidirectional connection for real-time event streaming
Risk Score	A numeric score (0-100+) representing an employee's cumulative risk
Heartbeat	A ping from an agent to the server every 5 minutes proving it's alive
Policy	A DLP rule: regex pattern + weight + regulation tags + category
Flagged	An employee marked for active security review by an admin
CRITICAL	Highest alert severity -- triggers immediate email notification
Escalation Count	How many times the same alert has been triggered within 4 hours
PIN	Employee authentication credential set by admin, min 4 chars
CHANGEME	Placeholder in .env -- server refuses to start if any secret is CHANGEME
Channel	The monitoring source where a violation was detected: CLIPBOARD, FILE, etc.
Deduplication	Merging repeated alerts within a 4-hour window to prevent alert fatigue
SOC	Security Operations Centre -- the team that monitors alerts